

Naravno. Objasniću detaljno šta je urađeno za svaki zahtev iz prve grupe i zašto je to bilo potrebno.

1. Status projekta je prikazan kao broj

Problem

U bazi/status enum-u projekat ima numeričku vrednost:

- 0
- 1
- 2
- 3

Frontend je direktno ispisivao taj broj:

```
Status: {project.status}
```

Zbog toga se korisniku prikazivalo:

- Status: 1
- Status: 2

što nema smisla za UI.

Šta sam uradio

U `ProjectList.jsx` sam dodao mapiranje:

```
const statusLabels = {  
  0: 'U pripremi',  
  1: 'U realizaciji',  
  2: 'Kompletiran',  
  3: 'Arhiviran'  
};
```

i funkciju:

```
const getStatusLabel = (status) => {  
  const value = typeof status === 'number' ? status : Number(status);  
  return statusLabels[value] || statusLabels[status] || 'Nepoznat status';  
};
```

zatim umesto:

```
Status: {project.status}
```

sada ide:

```
Status: {getStatusLabel(project.status)}
```

Rezultat

Korisnik sada vidi:

- U pripremi
- U realizaciji
- Kompletiran
- Arhiviran

umesto brojeva.

2. Prikazuju se projekti koji ne treba da budu dostupni

Problem

Na stranici „Korisnici“ prikazivali su se:

- Draft projekti (U pripremi)
- Archived projekti (Arhiviran)

što ne treba da bude javno vidljivo.

Ali:

- na „Moji projekti“ korisnik mora da vidi sve svoje projekte.

Dakle:

- javni pregled → samo aktivni i završeni projekti
- privatni pregled → svi projekti

Šta sam uradio

Backend

Dodao sam novu metodu u repository:

```
Task<List<Project>> GetVisibleByUserIdAsync(string userId);
```

Implementacija:

```
.Where(p =>
    p.UserId == userId &&
    (p.Status == ProjectStatus.Published || p.Status ==
    ProjectStatus.Completed))
```

Dakle vraća samo:

- Published
- Completed

Service sloj

U:

```
GetByUserIdAsync
```

sada koristim:

```
GetVisibleByUserIdAsync
```

dok za:

```
GetOwnedAsync
```

ostaje:

```
GetByUserIdAsync
```

što znači:

- vlasnik vidi sve,
- drugi korisnici vide samo dozvoljene.

Frontend

Dodatno sam dodao zaštitu:

```
showAllStatuses={false}
```

na stranici „Korisnici“.

I filter:

```
projects.filter(...)
```

koji propušta samo:

- 1
- 2

Rezultat

Na „Korisnici“:

☒ nema draft/arhiviranih projekata

Na „Moji projekti“:

☒ korisnik vidi sve svoje projekte

3. Prikazuju se administratori u listi korisnika

Problem

API je slao sve korisnike iz baze.

To znači da frontend dobija:

- obične korisnike
- administratore

što je bezbednosni problem.

Važna stvar:
frontend NE SME ni da dobije te podatke.

Dakle problem mora da se rešava na serveru.

Šta sam uradio

U `UserRepository.cs` sam promenio query.

Umesto:

```
_context.Users
```

sada radim JOIN sa:

- `UserRoles`
- `Roles`

i filtriram:

```
where role.Name == "User"
```

Rezultat

Server sada vraća samo korisnike sa rolom "User".

Administratori:

- ne dolaze do frontenda,
 - ne mogu biti prikazani,
 - ne mogu procureti kroz API.
-

4. Klikom na „Izmeni“ treba naglasiti karticu

Problem

Korisnik klikne „Izmeni“, ali ne vidi jasno:

- koji projekat trenutno menja.

To je čisto UX/UI problem.

Šta sam uradio

Dodao sam stanje:

```
selectedProjectId
```

Kada klikne:

```
handleSelectProject(project.id)
```

pamti se ID selektovanog projekta.

U ProjectList

Dodao sam:

```
className={`project-card ${selectedProjectId === project.id ? 'selected' : ''}`}
```

U CSS

Dodao sam:

```
&.selected {  
  background-color: #eef4ff;  
  border-color: #7da7ff;  
  box-shadow: ...  
}
```

Rezultat

Klik na „Izmeni“:

 vizuelno označi karticu

kao na slici iz zadatka.

5. Ne radi izmena datuma početka

Problem

Frontend je slao datum u formatu koji backend nije pravilno obrađivao.

Uz to:

- forma nije pravilno popunjavala `datetime-local`,
- backend nije eksplicitno ažurirao `StartedAt`.

Šta sam uradio

Frontend

Za `datetime-local` mora format:

`YYYY-MM-DDTHH:mm`

Zato:

```
project.startedAt.substring(0, 16)
```

Pri slanju

Dodao:

```
new Date(data.startedAt).toISOString()
```

da backend dobije validan ISO datum.

Backend

U `UpdateAsync`:

```
project.StartedAt = dto.StartedAt;
```

sada se eksplicitno ažurira.

Rezultat

- ✓ datum može da se menja
 - ✓ vrednost ostaje sačuvana u bazi
-

6. Projekti se misteriozno brišu ili menjaju

Ovo je najvažniji deo.

Problem

Postojao je ozbiljan bezbednosni propust.

API je primao:

```
PUT /projects/5  
DELETE /projects/5
```

ali nije proveravao:

- da li projekat pripada prijavljenom korisniku.

To znači:

Ako korisnik pogodi ID tuđeg projekta:

- može da ga menja,
- može da ga obriše.

To je klasičan:

IDOR vulnerability

(Insecure Direct Object Reference)

Veoma čest security bug.

Šta sam uradio

U servisima

Dodao proveru vlasništva.

Prvo:

```
var currentUser = await _userManager.FindByNameAsync(username);
```

zatim:

```
if (project.UserId != currentUser.Id)
{
    throw new UnauthorizedException(...);
}
```

i za:

- update
- delete

Rezultat

Sada korisnik može da menja/briše:

 samo svoje projekte

Ne može:

 tuđe projekte

čak ni ako zna njihov ID.

Važna napomena

Ovaj problem je morao da se rešava:

- na serveru,
- ne na frontendu.

Frontend zaštita nije dovoljna,
jer napadač može direktno slati HTTP zahteve API-ju.